

Sandboxing & Malware Analysis Workflow

The analysis pyramid

Triage (fast): hashes (VirusTotal), strings, YARA, pefile info

Static (no execution): Ghidra/IDA, objdump, unpacking, config extraction

Dynamic (execution, sandboxed): Cuckoo/ANY_RUN, syscall trace, network capture, process monitoring

Full RE (deep): reverse the loader, decode C2, extract IOCs

Sandbox basics

REMnux distro: analysis VM stack (REMnux + report)

Cuckoo Sandbox: automated VM guest reports (files, network, behavior)
– offline, config-heavy but free

CAPE: Cuckoo-derived with unpacking features

ANY_RUN / Joe / hybrid (cloud, careful with privacy)

Always run a fingerprint-avoiding guest (detect slowdown, VM strings
→ malware goes dormant)

A realistic dynamic session

```
# REMnux host:
cuckoo submit sample.exe          # or CAPE
# watch: created files, registry writes, network to unknown domains,
#         child processes (powershell from calc?), screenshots

# independent route: a Windows VM with:
#   - Procmon (process/file/reg trace)
#   - Process Hacker (tree+tips)
#   - FakeNet-NG (fake net capture)
#   - snapshot before, revert after
```

Network IOCs to hunt

Beaconing pattern (periodic POSTs)

DNS fast-flux / DGA subdomains

Unusual TLS JA3 / JA3S fingerprints

C2 domains from your sandboxed import: URLhaus, Abuse.ch

What 'analysis complete' looks like

A clean report: file hash(es), behavior timeline, configuration (C2 IPs, ports, mutex), MITRE technique mapping, and recommended detections (rules + EDR/network). Threat intel consumes it.

Malware analysis converts 'we saw a weird file' into 'we will see it 40 ways next time'. Its product is the detection rule, not just the story.

[← Rootkits & Bootkits](#)

[YARA: Writing Detection Rules →](#)